

Informe de Incidente de Seguridad (Análisis y Respuesta)

Objetivo: Documentar el hallazgo del compromiso, el análisis de los archivos afectados y las medidas técnicas tomadas para expulsar al atacante y asegurar el servidor.

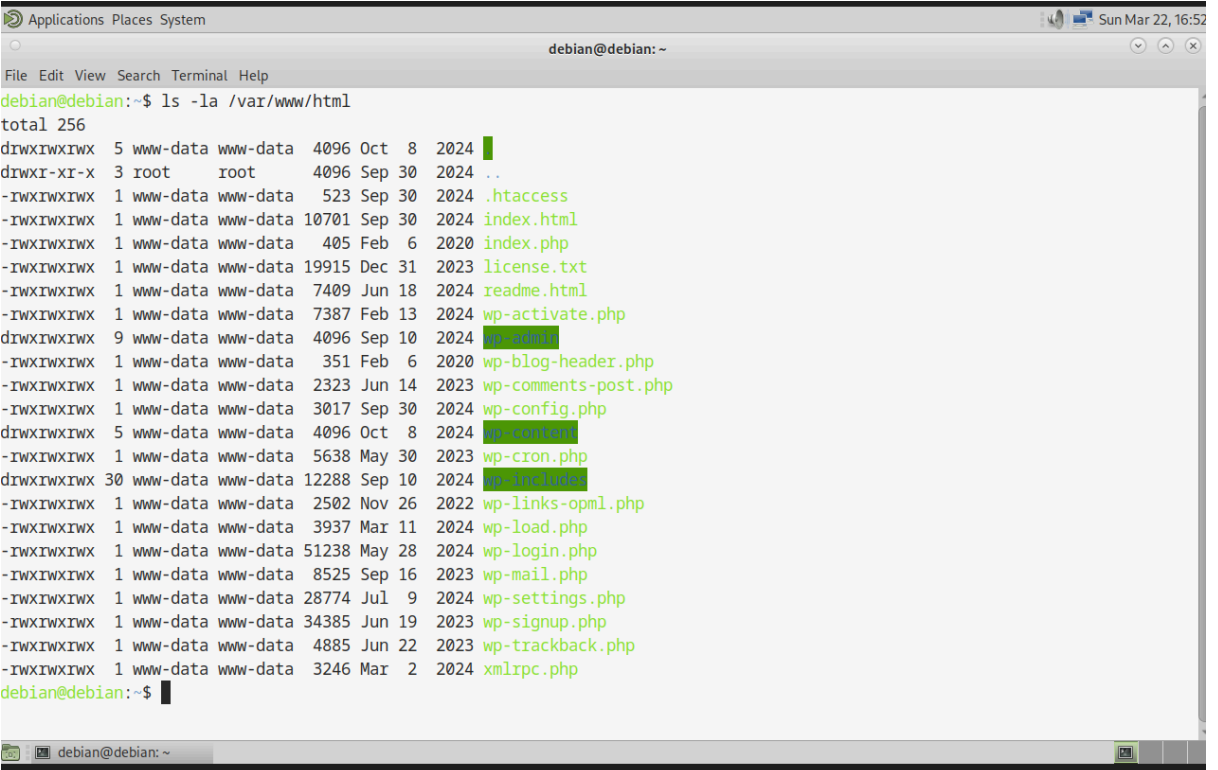
1. Detalles del Incidente

- **Fecha de detección:** 08 de octubre de 2024.
- **Naturaleza:** Compromiso de integridad en servidor web WordPress.
- **Síntomas:** Alteración de archivos `index.php` y presencia de procesos no identificados.

2. Análisis Forense (Hallazgos)

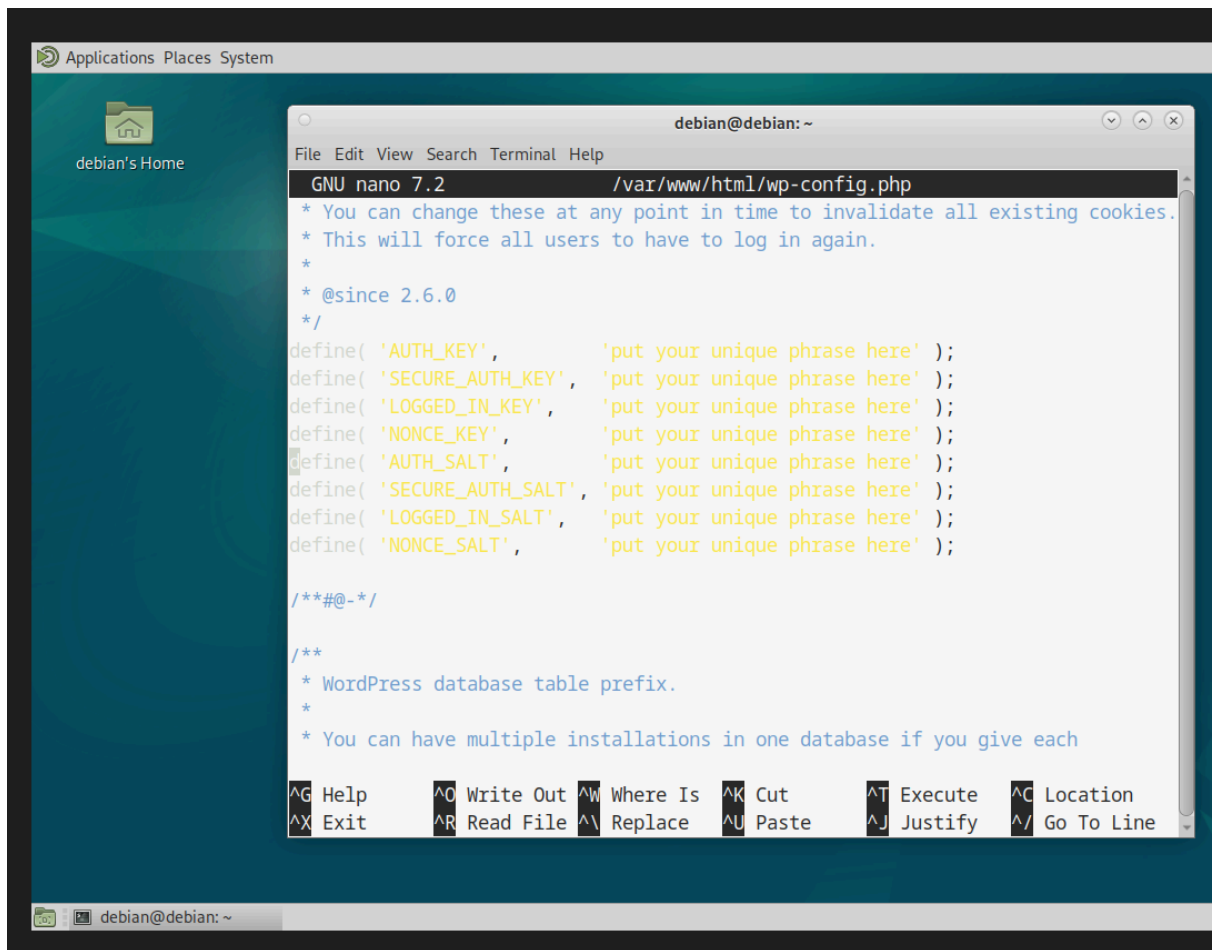
Tras la auditoría técnica, se determinaron los siguientes puntos de compromiso:

2.1. Manipulación del Sistema de Archivos: El atacante aprovechó permisos **777** para modificar el núcleo de la web. Se identificó que el archivo `index.php` fue sobrescrito.



```
Applications Places System
debian@debian: ~
File Edit View Search Terminal Help
debian@debian:~$ ls -la /var/www/html
total 256
drwxrwxrwx 5 www-data www-data 4096 Oct 8 2024 .
drwxr-xr-x 3 root root 4096 Sep 30 2024 ..
-rwxrwxrwx 1 www-data www-data 523 Sep 30 2024 .htaccess
-rwxrwxrwx 1 www-data www-data 10701 Sep 30 2024 index.html
-rwxrwxrwx 1 www-data www-data 405 Feb 6 2020 index.php
-rwxrwxrwx 1 www-data www-data 19915 Dec 31 2023 license.txt
-rwxrwxrwx 1 www-data www-data 7409 Jun 18 2024 readme.html
-rwxrwxrwx 1 www-data www-data 7387 Feb 13 2024 wp-activate.php
drwxrwxrwx 9 www-data www-data 4096 Sep 10 2024 wp-admin
-rwxrwxrwx 1 www-data www-data 351 Feb 6 2020 wp-blog-header.php
-rwxrwxrwx 1 www-data www-data 2323 Jun 14 2023 wp-comments-post.php
-rwxrwxrwx 1 www-data www-data 3017 Sep 30 2024 wp-config.php
drwxrwxrwx 5 www-data www-data 4096 Oct 8 2024 wp-content
-rwxrwxrwx 1 www-data www-data 5638 May 30 2023 wp-cron.php
drwxrwxrwx 30 www-data www-data 12288 Sep 10 2024 wp-includes
-rwxrwxrwx 1 www-data www-data 2502 Nov 26 2022 wp-links-opml.php
-rwxrwxrwx 1 www-data www-data 3937 Mar 11 2024 wp-load.php
-rwxrwxrwx 1 www-data www-data 51238 May 28 2024 wp-login.php
-rwxrwxrwx 1 www-data www-data 8525 Sep 16 2023 wp-mail.php
-rwxrwxrwx 1 www-data www-data 28774 Jul 9 2024 wp-settings.php
-rwxrwxrwx 1 www-data www-data 34385 Jun 19 2023 wp-signup.php
-rwxrwxrwx 1 www-data www-data 4885 Jun 22 2023 wp-trackback.php
-rwxrwxrwx 1 www-data www-data 3246 Mar 2 2024 xmlrpc.php
debian@debian:~$
```

2.2. Persistencia por Credenciales Expuestas: Al inspeccionar `wp-config.php`, se confirmó que el atacante tuvo acceso a las claves de la base de datos y a las **Salts** de seguridad. Al no estar personalizadas, el atacante podía generar cookies de sesión válidas.



```
Applications Places System
debian's Home

debian@debian: ~
File Edit View Search Terminal Help
GNU nano 7.2 /var/www/html/wp-config.php
* You can change these at any point in time to invalidate all existing cookies.
* This will force all users to have to log in again.
*
* @since 2.6.0
*/
define( 'AUTH_KEY',          'put your unique phrase here' );
define( 'SECURE_AUTH_KEY',  'put your unique phrase here' );
define( 'LOGGED_IN_KEY',    'put your unique phrase here' );
define( 'NONCE_KEY',        'put your unique phrase here' );
define( 'AUTH_SALT',        'put your unique phrase here' );
define( 'SECURE_AUTH_SALT', 'put your unique phrase here' );
define( 'LOGGED_IN_SALT',   'put your unique phrase here' );
define( 'NONCE_SALT',       'put your unique phrase here' );

/**#@-*/

/**
 * WordPress database table prefix.
 *
 * You can have multiple installations in one database if you give each
 */
^G Help      ^O Write Out ^W Where Is  ^K Cut       ^T Execute  ^C Location
^X Exit      ^R Read File ^\ Replace  ^U Paste     ^J Justify  ^_ Go To Line
```

3. Medidas de Remediación (Hardening)

Para erradicar la amenaza, se aplicaron las siguientes acciones (Basadas en el Punto 4 que ya corregimos):

3.1. Aplicación de Mínimo Privilegio: Se ejecutó una limpieza profunda de permisos:

- Directorios a **755**.
- Archivos a **644**.

```
debian@debian:~$ ls -la /var/www/html
total 256
drwxr-xr-x 5 www-data www-data 4096 Mar  5 19:25 .
drwxr-xr-x 3 root      root    4096 Sep 30 2024 ..
-rw-r--r-- 1 www-data www-data  523 Sep 30 2024 .htaccess
-rw-r--r-- 1 www-data www-data  405 Feb  6 2020 index.php
-rw-r--r-- 1 www-data www-data 19903 Mar  5 19:22 license.txt
-rw-r--r-- 1 www-data www-data  7425 Mar  5 19:22 readme.html
-rw-r--r-- 1 root      root      20 Mar  5 19:16 test.php
-rw-r--r-- 1 www-data www-data  7349 Mar  5 19:04 wp-activate.php
drwxr-xr-x 9 www-data www-data 4096 Sep 10 2024 wp-admin
-rw-r--r-- 1 www-data www-data  351 Feb  6 2020 wp-blog-header.php
-rw-r--r-- 1 www-data www-data 2323 Jun 14 2023 wp-comments-post.php
-rw-r--r-- 1 www-data www-data 3309 Mar  5 19:02 wp-config.php
-rw-r--r-- 1 www-data www-data 3339 Mar  5 19:04 wp-config-sample.php
drwxr-xr-x 7 www-data www-data 4096 Mar  5 19:23 wp-content
-rw-r--r-- 1 www-data www-data 5617 Mar  5 19:04 wp-cron.php
drwxr-xr-x 31 www-data www-data 16384 Mar  5 19:04 wp-includes
-rw-r--r-- 1 www-data www-data 2493 Mar  5 19:04 wp-links-opml.php
-rw-r--r-- 1 www-data www-data 3937 Mar 11 2024 wp-load.php
-rw-r--r-- 1 www-data www-data 51437 Mar  5 19:04 wp-login.php
-rw-r--r-- 1 www-data www-data  8727 Mar  5 19:04 wp-mail.php
-rw-r--r-- 1 www-data www-data 31055 Mar  5 19:04 wp-settings.php
-rw-r--r-- 1 www-data www-data 34516 Mar  5 19:04 wp-signup.php
-rw-r--r-- 1 www-data www-data  5214 Mar  5 19:04 wp-trackback.php
-rw-r--r-- 1 www-data www-data  3205 Mar  5 19:04 xmlrpc.php
debian@debian:~$
```

3.2. Cierre Perimetral (Firewall UFW): Se bloqueó el acceso externo al puerto 21 (FTP) y 3306 (MySQL), permitiendo solo tráfico web y administrativo seguro.

```
debian@debian:~$ sudo ufw status verbose
[sudo] password for debian:
Sorry, try again.
[sudo] password for debian:
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

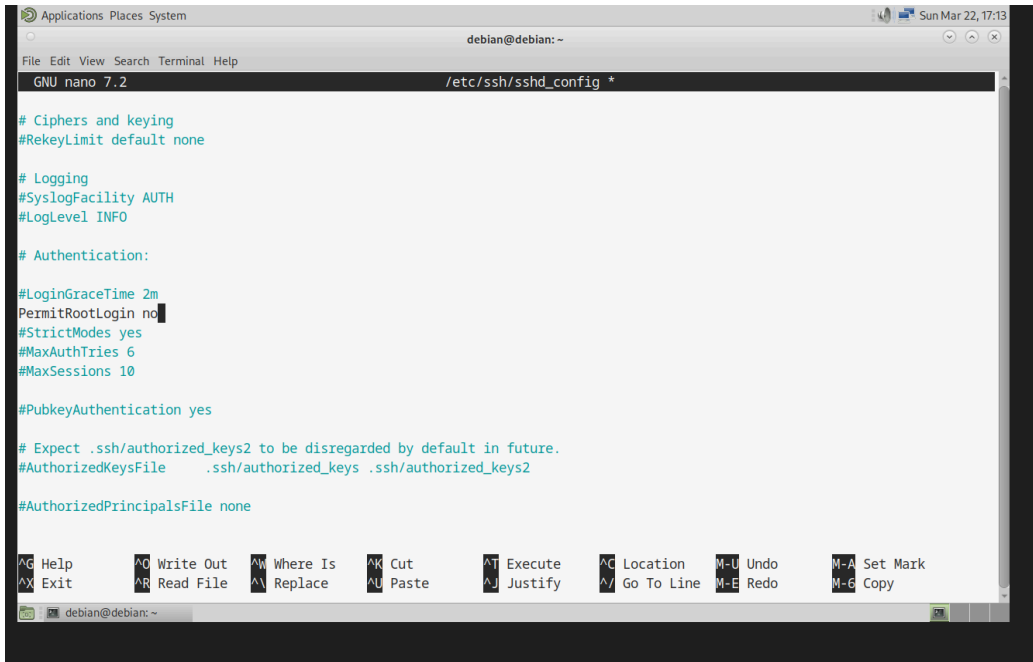
To Action From
--
22/tcp ALLOW IN Anywhere

80/tcp ALLOW IN Anywhere

22/tcp (v6) ALLOW IN Anywhere (v6)

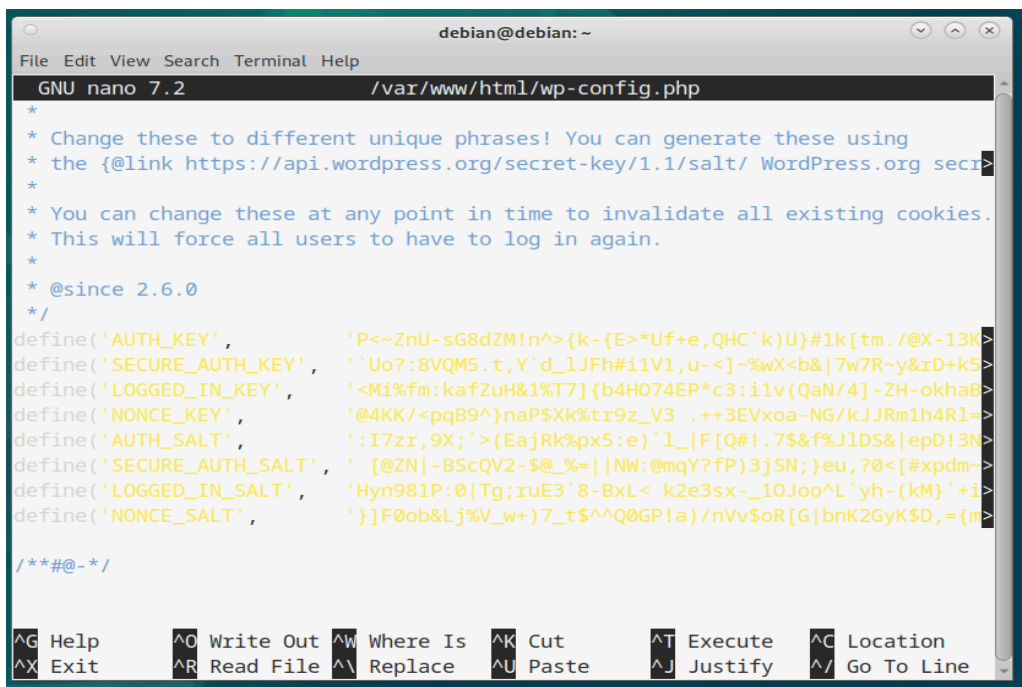
80/tcp (v6) ALLOW IN Anywhere (v6)
```

3.3. Hardening de Acceso SSH: Se deshabilitó el acceso directo al usuario **Root** para prevenir ataques de fuerza bruta exitosos.



```
debian@debian: ~  
GNU nano 7.2 /etc/ssh/sshd_config *  
  
# Ciphers and keying  
#RekeyLimit default none  
  
# Logging  
#SyslogFacility AUTH  
#LogLevel INFO  
  
# Authentication:  
  
#LoginGraceTime 2m  
PermitRootLogin no  
#StrictModes yes  
#MaxAuthTries 6  
#MaxSessions 10  
  
#PubkeyAuthentication yes  
  
# Expect .ssh/authorized_keys2 to be disregarded by default in future.  
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2  
  
#AuthorizedPrincipalsFile none  
  
^G Help ^O Write Out ^W Where Is ^K Cut ^T Execute ^C Location M-U Undo M-A Set Mark  
^X Exit ^R Read File ^N Replace ^U Paste ^J Justify ^_ Go To Line M-E Redo M-G Copy  
debian@debian: ~
```

3.4. Invalidación de Sesiones (Salts): Se regeneraron las llaves de seguridad en WordPress para expulsar cualquier sesión activa del atacante.



```
debian@debian: ~  
GNU nano 7.2 /var/www/html/wp-config.php  
  
*  
* Change these to different unique phrases! You can generate these using  
* the {@link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret key service}  
*  
* You can change these at any point in time to invalidate all existing cookies.  
* This will force all users to have to log in again.  
*  
* @since 2.6.0  
*/  
define('AUTH_KEY', 'P<~ZnU-sG8dZM!n^>{k-{E>*Uf+e,QHC`k)U}#1k[tm./@X-13K>  
define('SECURE_AUTH_KEY', '`Uo?:8VQM5.t,Y`d_lJFh#i1V1,u-<]~%wX<b&|7w7R~y&xD+k5>  
define('LOGGED_IN_KEY', '<Mi%fm:kafZuH&1%T7]{b4H074EP*c3:i1v(QaN/4)-ZH-okhaB>  
define('NONCE_KEY', '@4KK/<pqB9^}naP$Xk%tr9z_V3 .++3EVxoa-NG/kJJRm1h4R1=>  
define('AUTH_SALT', ':I7zr,9X;`>(EajRk%px5:e)`l_|F[Q#!.7$&f%JlDS&|epD!3N>  
define('SECURE_AUTH_SALT', '[@ZN| -BScQV2-$@_%=| |NW:@mqY?fP)3jSN; }eu, ?0<[#xpdm->  
define('LOGGED_IN_SALT', 'Hyn981P:0|Tg;ruE3`8-BxL< k2e3sx-_10Joo^L`yh-(kM)`+i>  
define('NONCE_SALT', '}]F0ob&Lj%V_w+)7_t$^Q0GP!a)/nVv$or[G|bnK2GyK$D,={m>  
  
/**#@-*/
```